kustom pada menu *Triggers*, mengonfigurasi daftar putih allowedIps dan kunci rahasia validKey, serta mengaktifkan aturan transformasi (*Transform Rules*) pada Cloudflare untuk **menghapus tajuk IP pengunjung (*Remove visitor IP headers*)**, seluruh permintaan keluar dari agregator akan tampak berasal dari jaringan tepi Cloudflare tanpa membocorkan identitas server asal.

Tata Kelola Keamanan Agentik (Zero-Trust Agent Governance)

Mengingat agen otonom yang dilengkapi dengan model *uncensored* dan akses terminal memiliki kapabilitas eksekusi yang sangat kuat, sistem harus mencegah perilaku destruktif yang tidak disengaja terhadap server induk. Integrasi **Agent Governance Toolkit** dari Microsoft menyediakan infrastruktur tata kelola *runtime* deterministik yang mencakup kesepuluh risiko **OWASP Agentic Top 10** lintas bahasa pemrograman (Python, TypeScript, .NET, Rust, dan Go) melalui penegakan kebijakan deterministik, identitas *zero-trust*, dan *sandboxing* eksekusi. Seluruh eksekusi kode yang dihasilkan oleh agen wajib dijalankan di dalam lingkungan kotak pasir (*sandbox*) terisolasi dengan hak akses minimum (*least-privilege access*), pencatatan jejak (*tracing & observability*) untuk pemutaran ulang deterministik (*deterministic replay*), serta gerbang persetujuan manusia (*Human-in-the-Loop approval gates*) untuk aksi sensitif.

Cetak Biru Implementasi Terpadu: Sintesis Sistem Otonom End-to-End

Untuk merealisasikan seluruh temuan riset ini ke dalam satu sistem produksi yang kohesif, komponen-komponen kode terbuka dari GitHub dan Hugging Face harus dirangkai mengikuti topologi modular yang memisahkan bidang kendali (*control plane*), bidang perutean (*routing plane*), bidang eksekusi lokal (*local inference plane*), dan bidang akuisisi eksternal (*external acquisition plane*).

Lapisan Sistem	Komponen Primer yang Dipilih	Komponen Sekunder / Cadangan	Peran Operasional dalam Agregator Otonom
1. Jaringan Tepi & Proksi	Calcium-Ion/new-api-worker (Cloudflare) + jhao104/proxy_pool	monosans/proxy-list (socks5.txt / proxies.json)	Menyembunyikan IP server induk melalui Cloudflare Transform Rules dan merotasi IP perayap web setiap jam
2. Agregator Kuota Gratis	diegosouzapw/OmniRoute + tashfeenahmed/freellmapi	decolua/9rou[span_381](start_span)[span_381](end_span)[span_383](start_span)[span_383](end_span)[span_385](start_span)[span_385](end_span)ter + justlovemaki/AIClient2API	Mengumpulkan 7,4 miliar token/bulan dan 150+ penyedia gratis ke dalam titik akhir /v1 standar
3. Gateway & Smart Router	Calcium-Ion/new-api-horiz[span_403](start_span)[span_403](end_span	BerriAI/litellm + weave-os/router + BlockRunAI/ClawRoute	Mengelola distribusi kunci, *caching* Redis, dan merutekan kueri

Lapisan Sistem	Komponen Primer yang Dipilih	Komponen Sekunder / Cadangan	Peran Operasional dalam Agregator Otonom
	)[span_404](start_span)[span_404](end_span)on + lm-sys/RouteLLM (mf)	r	berdasarkan ambang batas kompleksitas \tau = 0,11593
4. Mesin Inferensi Lokal	llama.cpp (llama-ser[span_408](start_span)[span_408](end_span)[span_409](start_span)[span_409](end_span)[span_410](start_span)[span_410](end_span)ver) + vLLM + SGLang-Omni	Edge0-AI/Edge0 (untuk perangkat RAM 2,5 GB) + Ollama	Menjalankan model GGUF/Safetensors secara lokal untuk kueri sensitif dan tugas tanpa sensor dengan biaya nol
5. Model SOTA & Uncensored	DeepSeek-R1-0528-Qwen3-8B + bartowski/mlabon[span_413](start_span)[span_413](end_span)[span_414](start_span)[span_414](end_span)ne_Qwen3-14B-abliterated-GGUF	mradermacher/Qwen3-30B-A3B-ablitera[span_415](start_span)[span_415](end_span)[span_416](start_span)[span_416](end_span)ted-GGUF + AIAnytime/ablate	Menyediakan penalaran SOTA (86,0% AIME24) dan kepatuhan instruksi penuh tanpa penolakan melalui *abliteration*
6. Mesin Multimodal SOTA	Video: HunyuanVideo-1.5 / LTX-2 (LT[span_419](start_span)[span_419](end_span)[span_420](start_span)[span_420](end_span)[span_421](start_span)[span_421](end_span)X-VideoQ8) / Wan2.2-TI2V-5B	Suara: fish-speech (S2-Pro / Dr[span_422](start_span)[span_422](end_span)[span_423](start_span)[span_423](end_span)ama 3) + hexgrad/Kokoro-82M	Menghasilkan video 60 detik pada VRAM 8–10 GB dan sintesis suara multi-karakter beremosi dengan RTF 0,195
7. Orkestrasi Agen & Memori	OpenClaw (5.380 *skills*) + Nous Hermes Age[span_427](start_span)[span_427](end_span)[span_428](start_span)[span_428](end_span)[span_429](start_span)[span_429](end_span)[span_430](start_span)[span_430](end_span)nt +	Memori: mem0ai/mem0 + letta-ai/let[span_431](start_span)[span_431](end_span)[span_432](start_span)[span_432](end_span)[span_433](start_span)[span_433](end_span)ta; Web: unclecode/crawl4ai	Mengeksekusi perencanaan multi-langkah, evolusi keterampilan mandiri, ingatan lintas sesi, dan ekstraksi web

Lapisan Sistem	Komponen Primer yang Dipilih	Komponen Sekunder / Cadangan	Peran Operasional dalam Agregator Otonom
	huggingface/smolagents		
8. Perisai Keamanan & Audit	protectai/modelscan + Format Safetensors / GGUF	Microsoft Agent Governance To[span_437](start_span)[span_437](end_span)[span_438](start_span)[span_438](end_span) olkit + mksglu/context-mode	Memblokir serangan serialisasi *pickle* sebelum pemuatan model dan membatasi ruang gerak agen sesuai standar OWASP

Sintesis arsitektural di atas menghasilkan tiga implikasi strategis tingkat lanjut bagi pengembangan ekosistem akademik dan penciptaan produk berfundamental tinggi di masa depan. Pertama, tercapainya **kemandirian komputasi melalui arbitrase perutean asimetris**: dengan menempatkan lm-sys/RouteLLM atau weave-os/router di depan OmniRoute dan freellmapi, serta menghubungkan *weak model* ke DeepSeek-R1-0528-Qwen3-8B atau Qwen3-8B-abliterated-GGUF yang berjalan di llama.cpp lokal, sebuah sistem agentik dapat memproses sebagian besar beban kerja analitis, ekstraksi data, dan instruksi tanpa sensor secara lokal tanpa biaya sepeser pun, sementara kueri berderajat kompleksitas ekstrem dirutekan secara otomatis ke kuota gratis dari 635 titik akhir eksternal. Apabila perangkat keras lokal memiliki kapasitas GPU menganggur di luar jam riset aktif, node tersebut dapat langsung dihubungkan ke Subnet 27 Bittensor (commune-ai/compute-ni) atau jaringan Nosana untuk mengakumulasi insentif token secara otonom.

Kedua, terwujudnya **dekonstruksi sensor tanpa degradasi kognitif maupun risiko siber**. Penggabungan teknik *Norm-Preserving Biprojected Abliteration* (jim-plus/llm-abliteration dan Orion-zhen/abliteration) serta optimasi subruang terpandu D_{\text{KL}} (AIAnytime/ablate dan p-e-w/heretic) membuktikan bahwa penghapusan sensor tidak lagi memerlukan pelatihan ulang dataset yang berisiko merusak kecerdasan model. Selama seluruh artefak bobot yang dihasilkan disimpan dan dipertukarkan secara ketat dalam format .safetensors atau .gguf serta diaudit menggunakan protectai/modelscan pada jalur integrasi, peneliti dapat mengoperasikan model tanpa filter dengan jaminan matematis dan kriptografis bahwa tidak ada instruksi eksekusi *malware* yang tersembunyi di dalam tensor model. Ketiga, terjadinya **konvergensi antara agen berevolusi mandiri dan multimodalitas lokal**: kemampuan agen generasi baru seperti OpenClaw, Hermes Agent, dan GenericAgent untuk mengkristalisasi keterampilan baru secara mandiri, dikombinasikan dengan efisiensi memori ekstrem pada model video (LTX-VideoQ8 pada 8 GB VRAM dan HunyuanVideo-Avatar pada 10 GB VRAM melalui TeaCache dan Wan2GP) serta model suara (Kokoro-82M pada CPU dan Fish Speech S2-Pro dengan kontrol tag emosi), memungkinkan satu stasiun kerja tunggal untuk beroperasi sebagai studio riset dan produksi multimedia otonom yang sepenuhnya gratis, privat, dan berdaulat.

Karya yang dikutip

1. Awesome-Agentic-AI-Learning-Resource-By-DevKay - GitHub, https://github.com/DharminJoshi/Awesome-Agentic-AI-Learning-Resource-By-DevKay 2. mfornos/awesome-agentic-ai: A curated list of principles ... - GitHub,

https://github.com/mfornos/awesome-agentic-ai 3. Organizations, Security, and the Hub API - Hugging Face, https://huggingface.co/docs/hub/other 4. AIAnytime/ablate: Ablate — directional ablation (abliteration ... - GitHub, https://github.com/AIAnytime/ablate 5. A curated list of awesome LLM/AI model routing ... - GitHub, https://github.com/yenanjing/awesome-model-routing 6. Uncensor LLMs via abliteration - no TransformerLens - GitHub, https://github.com/spkgyk/abliteration 7. GitHub - aloth/awesome-ai-agents, https://github.com/aloth/awesome-ai-agents 8. bartowski/mlabonne_Qwen3-8B-abliterated-GGUF - Hugging Face, https://huggingface.co/bartowski/mlabonne_Qwen3-8B-abliterated-GGUF 9. GitHub - monosans/proxy-list: Free HTTP, SOCKS4 and SOCKS5, https://github.com/monosans/proxy-list 10. lm-sys/RouteLLM: A framework for serving and evaluating LLM routers, https://github.com/lm-sys/routellm 11. Issues · songquanpeng/one-api - GitHub, https://github.com/songquanpeng/one-api/issues 12. GitHub - ripienaar/free-for-dev: A list of SaaS, PaaS and IaaS, https://github.com/ripienaar/free-for-dev 13. RaoFoundation/bittensor: Internet-scale Neural Networks - GitHub, https://github.com/RaoFoundation/bittensor 14. nosana-llm-benchmarking - GitHub, https://github.com/nosana-ci/nosana-llm-benchmarking 15. GitHub - n8watkins/freestack: Search 1,200+ free developer tiers, https://github.com/n8watkins/freestack 16. chukwulasu - GitHub, https://github.com/chukwulasu 17. GitHub - jixserver/free-for-dev-1: A list of SaaS, PaaS and IaaS, https://github.com/jixserver/free-for-dev-1 18. GitHub - RaoFoundation/bittensor-subnet-template, https://github.com/opentensor/bittensor-subnet-template 19. score-predict/README.md at main - GitHub, https://github.com/score-technologies/score-predict/blob/main/README.md 20. commune-ai/compute-ni: Bittensor Compute Subnet - GitHub, https://github.com/commune-ai/compute-ni 21. bittensor-subnet-template/docs/running_on_testnet.md at main, https://github.com/opentensor/bittensor-subnet-template/blob/main/docs/running_on_testnet.md 22. The Nosana CLI. - GitHub, https://github.com/nosana-ci/nosana-cli 23. Nosana website. · GitHub, https://github.com/nosana-ci/nosana.io 24. You are not the owner of the device? · Issue #48 · ionet-official, https://github.com/ionet-official/io_launch_binaries/issues/48 25. dstripelis/Awesome-LLM-Routing - GitHub, https://github.com/dstripelis/Awesome-LLM-Routing 26. songquanpeng/one-api: LLM API 管理& 分发系统，支持OpenAI, https://github.com/songquanpeng/one-api 27. Package new-api - GitHub, https://github.com/users/Calcium-Ion/packages/container/new-api/353967521?tag=v0.4.7.0 28. Releases · songquanpeng/one-api - GitHub, https://github.com/songquanpeng/one-api/releases 29. GitHub - lachlanchen/LazyRouter: Private AI API gateway for user, https://github.com/lachlanchen/LazyRouter 30. Issues · Calcium-Ion/new-api-horizon - GitHub, https://github.com/Calcium-Ion/new-api-horizon/issues 31. Calcium-Ion/new-api-key-tool: New API 根据Key查询使用详情 - GitHub, https://github.com/Calcium-Ion/new-api-key-tool 32. Calcium-Ion/new-api-horizon: 特性版 - GitHub, https://github.com/Calcium-Ion/new-api-horizon 33. Releases · Calcium-Ion/new-api-horizon - GitHub, https://github.com/Calcium-Ion/new-api-horizon/releases 34. GitHub - BerriAI/litellm: The fastest, litest AI Gateway. Rust core with, https://github.com/BerriAI/litellm 35. [Feature]: Add a new routing strategy based on RouteLLM ... - GitHub, https://github.com/BerriAI/litellm/discussions/4753 36. Routing to Local Models with RouteLLM and Ollama - GitHub, https://github.com/lm-sys/RouteLLM/blob/main/examples/routing_to_local_models.md 37. 500 Panic detected · Issue #6352 · QuantumNous/new-api - GitHub,

https://github.com/QuantumNous/new-api/issues/6352 38. abliteration - Orion-zhen - GitHub, https://github.com/Orion-zhen/abliteration 39. protectai/modelscan: Protection against Model Serialization Attacks, https://github.com/protectai/modelscan 40. GitHub - andyrdt/refusal_direction: Code and results accompanying, https://github.com/andyrdt/refusal_direction 41. GitHub - jim-plus/llm-abliteration, https://github.com/jim-plus/llm-abliteration 42. Examining different datasets for Abliteration · Issue #472 - GitHub, https://github.com/p-e-w/heretic/issues/472 43. llm_notebooks/ABLITERATION.md at main · danielsobrado ... - GitHub, https://github.com/danielsobrado/llm_notebooks/blob/main/ABLITERATION.md 44. Wan-AI/Wan2.1-T2V-1.3B at main - Hugging Face, https://huggingface.co/Wan-AI/Wan2.1-T2V-1.3B/tree/main 45. deepseek-ai/DeepSeek-R1-0528-Qwen3-8B - Hugging Face, https://huggingface.co/deepseek-ai/DeepSeek-R1-0528-Qwen3-8B 46. Wan2.1 - a Wan-AI Collection - Hugging Face, https://huggingface.co/collections/Wan-AI/wan21 47. HunyuanVideo-1.5: A leading lightweight video generation model, https://github.com/Tencent-Hunyuan/HunyuanVideo-1.5 48. HunyuanVideo-Foley: Multimodal Diffusion with Representation, https://github.com/Tencent-Hunyuan/HunyuanVideo-Foley 49. Releases · fishaudio/fish-speech - GitHub, https://github.com/fishaudio/fish-speech/releases 50. fishaudio/fish-speech: SOTA Open Source TTS - GitHub, https://github.com/fishaudio/fish-speech 51. Open-R1: a fully open reproduction of DeepSeek-R1 - Hugging Face, https://huggingface.co/blog/open-r1 52. mradermacher/Qwen3-30B-A3B-abliterated-GGUF - Hugging Face, https://huggingface.co/mradermacher/Qwen3-30B-A3B-abliterated-GGUF 53. unsloth/DeepSeek-R1-GGUF - Hugging Face, https://huggingface.co/unsloth/DeepSeek-R1-GGUF 54. Official repository for LTX-Video - GitHub, https://github.com/Lightricks/ltx-video 55. Wan-AI/Wan2.2-TI2V-5B - Hugging Face, https://huggingface.co/Wan-AI/Wan2.2-TI2V-5B 56. HunyuanVideo: A Systematic Framework For Large Video ... - GitHub, https://github.com/Tencent-Hunyuan/HunyuanVideo 57. HunyuanVideo-I2V: A Customizable Image-to-Video Model ... - GitHub, https://github.com/Tencent-Hunyuan/HunyuanVideo-I2V 58. Tencent-Hunyuan/HunyuanVideo-Avatar - GitHub, https://github.com/tencent-hunyuan/hunyuanvideo-avatar 59. HunyuanVideo-1.5/LICENSE at main · Tencent-Hunyuan ... - GitHub, https://github.com/Tencent-Hunyuan/HunyuanVideo-1.5/blob/main/LICENSE 60. hexgrad/Kokoro-82M - Hugging Face, https://huggingface.co/hexgrad/Kokoro-82M 61. SWivid/F5-TTS - Hugging Face, https://huggingface.co/SWivid/F5-TTS 62. QwenAudio/CosyVoice: Multi-lingual large voice generation model, https://github.com/QwenAudio/CosyVoice 63. fishaudio/fish-speech at archy.net - GitHub, https://github.com/fishaudio/fish-speech?ref=archy.net 64. hexgrad/Kokoro-82M-v1.1-zh - Hugging Face, https://huggingface.co/hexgrad/Kokoro-82M-v1.1-zh 65. samples/make_en.py · hexgrad/Kokoro-82M-v1.1-zh at main, https://huggingface.co/hexgrad/Kokoro-82M-v1.1-zh/blob/main/samples/make_en.py 66. samples/make_zh.py · hexgrad/Kokoro-82M-v1.1-zh at main, https://huggingface.co/hexgrad/Kokoro-82M-v1.1-zh/blob/main/samples/make_zh.py 67. 2Noise/ChatTTS - Hugging Face, https://huggingface.co/2Noise/ChatTTS 68. SWivid/F5-TTS · Discussions - Hugging Face, https://huggingface.co/SWivid/F5-TTS/discussions 69. ai-agents · GitHub Topics, https://github.com/topics/ai-agents 70. jhao104/proxy_pool: Python ProxyPool for web spider - GitHub, https://github.com/jhao104/proxy_pool 71. GitHub -

adriannoes/awesome-agentic-ai, https://github.com/adriannoes/awesome-agentic-ai 72. GitHub - slavakurilyak/awesome-ai-agents, https://github.com/slavakurilyak/awesome-ai-agents 73. smolagents: a barebones library for agents that think in code. - GitHub, https://github.com/huggingface/smolagents 74. GitHub - mem0ai/mem0: The Memory Layer for AI Agents, https://github.com/mem0ai/mem0 75. Unauthenticated SSRF on the Docker server streaming crawl path, https://github.com/advisories/GHSA-wm69-2pc3-rmmf 76. Calcium-Ion/new-api-worker - GitHub, https://github.com/Calcium-Ion/new-api-worker 77. jhao104-proxy_pool - ccfleaf - GitHub, https://github.com/ccfleaf/jhao104-proxy_pool

Audit Forensik Akar Sistem dan Cetak Biru Arsitektur Otonom bikinAI Super Intelligence

Pengembangan agregator kecerdasan buatan otonom **bikinAI Super Intelligence** dari iterasi v3.4.0 menuju arsitektur tingkat lanjut (v3.5.0 dan standar Frontier v4.0) menuntut pembedahan forensik hingga ke lapisan kode paling dasar. Fokus utama dari rekayasa sistem ini adalah membangun ekosistem multi-agen yang mampu memutar model-model mutakhir—mulai dari Gemini 4 Argon, Qwen 3.6 dan 3.8, DeepSeek V4, Meta Muse, nanoMuse, Nous Hermes 3, hingga kerangka kerja OpenHands Harness—dengan biaya operasional mendekati Rp 0 melalui agregasi sumber daya komunitas (*Omni-Resource Harvester* atau "Bot Bansos"). Pada saat yang bersamaan, arsitektur ini dirancang untuk menjaga isolasi keamanan berlapis (*Defense-in-Depth*), menjamin kepatuhan hukum dua arah melalui mekanisme *Stateless Compute Voucher* (Ed25519) menuju portal independen **NocturneAI**, serta menghasilkan rasio keuntungan harian di atas 1.000% secara realistis dan terukur bagi pengelola sistem.

Diagnosis Forensik Kode Sumber dan Kerentanan Akar pada Mesin v3.4.0 hingga v3.5.0

Pemeriksaan baris demi baris terhadap basis kode produksi App.py (v3.4.0) dan dokumentasi pemulihan router pada v3.5.0 mengungkap delapan celah logika, keamanan, dan ekonomi yang berada tepat di jantung sistem. Walaupun kesalahan sintaksis pada baris 356 (stripped_threats = []) dan hilangnya blok penghubung @router.callback_query akibat pemotongan baris antara Bagian 2 dan Bagian 3 telah teridentifikasi pada iterasi v3.5.0, terdapat kerentanan struktural yang jauh lebih krusial apabila sistem diluncurkan ke publik tanpa penambalan arsitektural secara menyeluruh.

1. Celah Pencetakan Koin Gratis Tanpa Batas dan Manipulasi Brankas pada Kasir Otomatis

Pada fungsi handle_customer_menu_callbacks di dalam App.py, terdapat celah logika fatal pada penanganan action == "topup_verify". Ketika pengguna menekan tombol ✅ Verifikasi Pembayaran Otomatis (+60 Koin) (callback_data="menu:topup_verify"), sistem langsung mengeksekusi transaksi SQL UPDATE users SET koin_utama = koin_utama + 60, has_topped_up = 1 dan memanggil record_job_and_split_profit(db, revenue_idr=5000, actual_hpp_idr=800) tanpa memeriksa status pembayaran ke API Payment Gateway (Pakasir, Duitku, Midtrans, atau @CryptoBot) maupun memverifikasi mutasi QRIS. Akibatnya, pengguna mana pun dapat menekan tombol tersebut berkali-kali untuk mencetak koin_utama secara gratis tanpa batas, sekaligus memalsukan angka omzet kotor (gross_revenue_idr) dan laba siap panen (harvestable_profit_vault_idr) di dalam tabel treasury_summary.

2. Ketidakadaan Validasi Kriptografi HMAC-SHA256 dan Kebocoran

Render Gratis pada Endpoint Mini App

Teks kebijakan privasi di dalam MINIAPP_FULL_WEBSITE_HTML menyatakan bahwa komunikasi antara Mini App dan server dilindungi oleh tanda tangan kriptografi HMAC-SHA256. Namun, audit forensik pada fungsi JavaScript runGenerate() dan endpoint backend handle_webapp_execute_api (/api/webapp/execute) membuktikan bahwa klaim tersebut belum diimplementasikan di level kode. Antarmuka frontend hanya mengirimkan angka mentah st.user_id yang diambil dari tg.initDataUnsafe?.user tanpa menyertakan string bertanda tangan window.Telegram.WebApp.initData. Lebih jauh lagi, fungsi handle_webapp_execute_api di sisi server sama sekali tidak memanggil fungsi pemotongan saldo deduct_user_coins_for_job. Konsekuensi berantai dari celah ini sangat merugikan secara finansial maupun operasional karena pengguna yang melakukan render melalui Mini App tidak pernah dipotong koinnya sama sekali. Selain itu, apabila variabel user_id bernilai kosong atau 0 saat diakses dari peramban eksternal, ekspresi int(data.get("user_id") or RUNTIME_CONFIG["OWNER_ID_RUNTIME"] or 0) justru mengalihkan beban dan pengiriman hasil render ke ruang obrolan pribadi milik pengelola utama. Pihak luar yang memindai port 8080 juga dapat mengirimkan permintaan POST palsu berisi user_id acak untuk melakukan serangan *spamming* media ke pengguna Telegram mana pun atas nama bot tanpa autentikasi kriptografi.

3. Kebocoran Render Gratis dan Prompt Statis Terkunci pada Handler Foto dan Obrolan Alami

Pada bagian ke-12 (handle_multimodal_photo_and_pdf) dan bagian ke-13 (handle_natural_conversation) di dalam App.py, alur pemotongan koin dan pemeriksaan kuota harian dilewati sepenuhnya. Ketika pengguna mengunggah foto referensi (F.photo), sistem tidak mengunduh foto tersebut dari server Telegram (bot.download(message.photo[-1])) untuk dikirim ke model *Image-to-Image* atau *Reference Lock*, melainkan mengeksekusi variabel statis en_prompt = f"Cute cat holding a sign board with clear text 'ayo coba bikinAI', Indonesian street storefront, {clean_caption}, Seedream 4.5 8k photorealistic" dan merendernya secara gratis tanpa memotong koin. Hal serupa terjadi ketika pengguna mengetik kalimat "buat gambar ..." di ruang obrolan; sistem langsung memanggil fetch_clean_image_bytes dan mengirimkan gambar 4K beserta tombol *derivative upsell* tanpa memeriksa ataupun memotong saldo koin_bonus maupun koin_utama.

4. Kondisi Balapan (Race Condition) Pengambilalihan Hak Akses Owner

Fungsi penjaga keamanan is_verified_owner_dm(user_id: int, chat_type: str) memiliki logika otomatis if RUNTIME_CONFIG["OWNER_ID_RUNTIME"] == 0: RUNTIME_CONFIG["OWNER_ID_RUNTIME"] = user_id. Apabila pengelola belum mengisi variabel lingkungan ADMIN_USER_ID di dalam berkas .env saat server pertama kali dinyalakan, nilai awal OWNER_ID_RUNTIME berada pada angka 0. Pengguna eksternal pertama yang secara kebetulan atau sengaja mengetik /admin, /set_miniapp, atau /pasang_bansos di pesan pribadi bot akan langsung dikukuhkan oleh sistem sebagai pemilik sah dan disimpan secara permanen ke dalam tabel system_settings melalui save_persistent_setting(db, "OWNER_ID_RUNTIME", ...).

5. Ilusi Keamanan pada Sterilisasi AST Python (CVE-2026-40158)

Fungsi sterilize_community_script_ast di dalam App.py hanya mengandalkan penelusuran pohon sintaksis (ast.walk) untuk memblokir daftar hitam statis forbidden_calls = {"system", "popen", "eval", "exec", "spawnl", "getattr"} dan forbidden_imports = {"subprocess", "pty", "ctypes", "pickle"}. Berdasarkan temuan kerentanan keamanan agen AI tahun 2026 (**CVE-2026-40158** pada *sandbox* berbasis AST) serta literatur keamanan eksekusi kode Python, pendekatan daftar hitam AST di dalam proses (*in-process interpreter*) tidak mampu menghentikan penyerang maupun *malware* yang menyamar sebagai skrip komunitas. Fungsi bawaan seperti __import__, open, compile, dan breakpoint tidak masuk dalam forbidden_calls, sehingga skrip berbahaya cukup memanggil __import__("shutil").rmtree("/") atau membaca berkas /home/user/.bikinai_vault/ed25519_voucher_key.bin secara langsung menggunakan fungsi open() untuk mencuri kunci privat Ed25519 dan menguras seluruh isi brankas. Lebih jauh lagi, penyerang dapat melewati pemeriksaan ast.Call menggunakan traversi atribut kelas seperti ().__class__.__base__.__subclasses__() atau type.__getattribute__ untuk mengakses modul os dan builtins secara tidak langsung tanpa pernah menuliskan kata kunci yang diblokir. Karena modul jaringan seperti httpx, urllib, socket, dan aiohttp juga tidak diblokir di dalam proses utama, skrip komunitas yang lolos dapat mengirimkan seluruh isi os.environ (termasuk BOT_TOKEN, GROQ_API_KEY, GEMINI_API_KEY, dan kunci kasir) ke server eksternal milik peretas.

6. Kebocoran Privasi Identitas dan Pencetakan Voucher Tanpa Biaya pada Portal Eksternal

Saat pengguna menekan tombol 🌐 Portal Web Open-Source (Unfiltered) & Voucher (menu:unfiltered_external_referral), fungsi issue_stateless_ed25519_voucher(user_id, compute_units=10) menerbitkan voucher kriptografi tanpa memotong satu koin pun dari saldo pengguna. Karena setiap pemanggilan menghasilkan nilai acak nonce baru (os.urandom(8).hex()), pemeriksaan *nullifier* di tabel redeemed_nullifiers tidak dapat mencegah satu pengguna mencetak ribuan voucher gratis. Selain itu, struktur JSON voucher menyimpan "u": int(user_id) secara terbuka yang hanya dikodekan dengan Base64 URL-safe. Siapa pun yang mendekode string VCH-eyJuIjoi... dapat melihat ID Telegram asli milik pengguna, yang secara langsung menggugurkan prinsip *Zero-Log / Zero-Identity Linkage* antara bot Telegram SFW dan portal eksternal NocturneAI.

7. Pemborosan Kuota Enam Kali Lipat Akibat Simultaneous Hedging pada Detik Ke-Nol

Untuk mengatasi masalah bot yang harus ditanya 2 hingga 3 kali baru menjawab, fungsi generate_frontier_ai_response pada v3.4.0 menggunakan pola *Parallel Hedged Router* yang menembak seluruh penyedia API (Groq, OpenRouter, Gemini, 2 API Bansos, dan Pollinations) secara serentak pada detik ke-0 (asyncio.create_task paralel) lalu membatalkan tugas yang kalah cepat (t.cancel()). Dalam rekayasa sistem terdistribusi, membatalkan *task* asyncio di sisi klien setelah paket HTTP POST dikirim ke server tidak membatalkan pemrosesan inferensi di server penyedia API. Akibatnya, setiap satu pesan obrolan dari satu pengguna langsung menguras kuota *Requests Per Minute* (RPM) dan *Tokens Per Day* (TPD) pada kelima penyedia sekaligus. Dengan batas gratis Groq sebesar 30 RPM / 1.000 RPD dan Gemini AI Studio

sebesar 5–15 RPM, penembakan paralel buta pada t = 0 akan menghabiskan seluruh kuota gratis harian 5 hingga 6 kali lebih cepat dan memicu badai galat HTTP 429 Too Many Requests.

8. Kontensi Koneksi aiosqlite pada SingleWriterSQLiteDaemon

Meskipun sistem telah dilengkapi SingleWriterSQLiteDaemon dengan asyncio.Lock() dan 4.096 *lock stripes*, setiap handler di dalam App.py membuka koneksi baru menggunakan async with aiosqlite.connect(DB_PATH) as db: lalu menyerahkan objek db lokal tersebut ke DB_WRITER_DAEMON.execute_write_tx(db, _tx). Di dalam pustaka Python aiosqlite, setiap pemanggilan aiosqlite.connect() memintal satu *worker thread* baru di latar belakang. Apabila ratusan pengguna berinteraksi secara bersamaan di dalam grup komunitas, sistem akan memintal ratusan *thread* sistem operasi terpisah yang saling berebut *file lock* SQLite, sementara fungsi pemeliharaan _run_inline_maintenance berisiko tereksekusi pada koneksi yang sedang ditutup oleh blok konteks luarnya. Standar arsitektur yang benar menuntut penggunaan satu koneksi *singleton* persisten khusus penulisan di dalam daemon dan satu kumpulan koneksi baca (*read-pool*) di atas mode WAL (PRAGMA journal_mode = WAL).

ID Celah	Lokasi Fungsi pada App.py	Akar Masalah Teknis & Eksploitasi	Dampak pada Keamanan & Ekonomi	Solusi Arsitektur Permanen (Standar v4.0)
VULN-01	handle_customer_menu_callbacks (menu:topup_verify)	Penambahan +60 koin_utama dieksekusi langsung dari tombol tanpa cek API webhook/mutasi.	Pencetakan koin Pro gratis tak terbatas & pemalsuan saldo kas treasury_summary.	Hapus tombol verifikasi buta; ganti dengan *Webhook Listener* bertanda tangan HMAC (Pakasir/Duitku/CryptoBot) & *Polling API Mutasi*.
VULN-02	handle_webapp_execute_api (/api/webapp/execute)	Tidak ada validasi initData HMAC-SHA256 & tidak memanggil fungsi potong koin.	Render gratis tanpa batas via Mini App & potensi serangan *spamming* lintas akun.	Wajibkan header X-Telegram-Init-Data, validasi dengan hmac.compare_digest, cek *replay* \le 65\text{s}, dan panggil deduct_user_coins_for_job.
VULN-03	handle_multimodal_photo_and_pdf & handle_natural_conversation	Eksekusi fetch_clean_image_bytes langsung tanpa potong koin & prompt gambar kucing terkunci.	Kebocoran HPP render 4K gratis & kegagalan fitur referensi foto asli pengguna.	Integrasikan pengunduhan file_id foto Telegram ke endpoint *Vision/Img2Img* serta panggil pemotongan kuota/koin sebelum render.

ID Celah	Lokasi Fungsi pada App.py	Akar Masalah Teknis & Eksploitasi	Dampak pada Keamanan & Ekonomi	Solusi Arsitektur Permanen (Standar v4.0)
VULN-04	is_verified_owner_dm	Jika OWNER_ID_RUNTIME == 0, ID pengetik pertama otomatis diangkat menjadi Owner.	Pengambilalihan penuh panel /admin dan brankas /harvest oleh pihak luar.	Tolak akses /admin secara mutlak (*Fail-Closed*) apabila ADMIN_USER_ID di .env belum dikonfigurasi dengan angka valid >0.
VULN-05	sterilize_community_script_ast	Blokir statis ast.walk mudah ditembus via __import__, open(), atau type.__getattribute__.	Eksekusi kode jarak jauh (RCE) & pencurian kunci .env / ed25519_voucher_key.bin.	Isolasi eksekusi skrip komunitas di dalam *WebAssembly Sandbox* (wasmtime / MicroPython-WASM) dengan batas *fuel* CPU & tanpa akses I/O.
VULN-06	issue_stateless_ed25519_voucher (menu:unfiltered_external_referral)	Penerbitan voucher VCH-... tidak memotong koin & menyertakan "u": user_id dalam teks terang Base64.	Eksploitasi komputasi gratis di NocturneAI & kebocoran tautan identitas pengguna Telegram.	Potong koin secara atomik sebelum menerbitkan voucher (Escrow Burn) & ganti user_id dengan *Blinded Hash Commitment*.
VULN-07	generate_frontier_ai_response	Menembak 5–6 penyedia LLM sekaligus pada t = 0\text{ ms} untuk setiap pesan chat.	Kuota gratis RPM/TPD (Groq/Gemini/OpenRouter) habis 6x lebih cepat akibat beban ganda.	Terapkan *Staggered Hedging* (tembak penyedia ke-2 hanya jika penyedia ke-1 belum mengirim byte pertama setelah 1,2\text{ detik}).
VULN-08	SingleWriterSQLiteDaemon & seluruh handler aiosqlite	Membuka aiosqlite.connect() baru di setiap permintaan hingga memintal ratusan	*Database lock contention* & pemborosan RAM pada saat trafik grup sedang	Gunakan satu koneksi *Persistent Writer Singleton* dan koneksi *Read-Only Pool* di

ID Celah	Lokasi Fungsi pada App.py	Akar Masalah Teknis & Eksploitasi	Dampak pada Keamanan & Ekonomi	Solusi Arsitektur Permanen (Standar v4.0)
		worker thread.	tinggi.	atas mode WAL + migrasi opsional ke Turso libSQL.

Arsitektur Rolling Multi-Agentic AI dan Orkestrasi Staggered Hedging Zero-Cost

Untuk mewujudkan visi agregator super-intelijen yang praktis, tahan banting, dan selalu memiliki cadangan aktif saat satu penyedia mengalami gangguan (*rate-limit* atau pemadaman), sistem tidak boleh bergantung pada satu jenis model maupun satu jalur API. Analisis terhadap lanskap model dan infrastruktur AI pada tahun 2026 menunjukkan bahwa ketahanan tertinggi dicapai dengan mengelompokkan agen-agen ke dalam **Rolling Multi-Agentic Pool** yang diatur oleh algoritma **Staggered Speculative Hedging** serta **Client-Side Compute Offloading**.

Peta Kapabilitas Ekosistem Model dan Agen dalam Rolling Pool

Seluruh entitas model dan kerangka kerja agen yang diintegrasikan ke dalam ekosistem bikinAI memiliki spesialisasi fungsional yang saling melengkapi ketika diputar secara otomatis (*auto-rolling*). Pada lini penalaran dan multimodal Google, penyedia ini telah menghentikan layanan gemini-2.0-flash pada 1 Juni 2026—sebuah model yang masih tertulis secara *hardcoded* pada baris 563 di dalam App.py. Oleh karena itu, konfigurasi router wajib diperbarui ke keluarga **Gemini 3.8 Flash** dan **Gemini 2.5 Flash-Lite** yang menyediakan kuota gratis 250.000 TPM melalui Google AI Studio, serta **Gemini 4 Argon** (google/gemini-4-argon) yang berperan sebagai model *flagship* penalaran kompleks Google dan dapat diakses tanpa biaya server melalui jembatan klien Puter.js. Di sisi lain, kekuatan pemrograman agen dan pemrosesan multibahasa ditopang oleh keluarga **Alibaba Qwen3 dan Qwen 3.6/3.8**, yang mencakup **Qwen 3.8 Max**, **Qwen 3.6-Plus/Max**, **Qwen3-235B**, **Qwen3-Coder-480B-A35B-Instruct**, serta **Qwen 3.6-27B**. Model-model Qwen ini menawarkan jendela konteks hingga 1 juta token untuk pemrograman tingkat repositori serta tersedia secara gratis melalui **Groq** (30 RPM, 1.000 RPD), **SiliconFlow** (¥0 tanpa kartu kredit), **Qwen Studio**, dan **OpenRouter**.
Untuk tugas riset mendalam (/riset), matematika, dan logika kode di /canvas, ekosistem mengandalkan keluarga **DeepSeek V3.2, V4 Pro, dan R1**. Platform resmi DeepSeek memberikan alokasi kredit awal sebesar 5 juta token gratis (berlaku 30 hari dengan konteks 1 juta token), sementara varian komunitas tanpa filter (deepseek-v4.1-flash-uncensored dan deepseek-chat:free) dapat dirotasi melalui **OpenRouter**, **SiliconFlow**, dan **Puter.js**. Pada ranah produksi kreatif konsumen dan kolaborasi audio-video, **Meta Muse Family** (Muse Spark, Muse Wonder, dan Muse Video) yang diluncurkan oleh Meta Superintelligence Labs pada tahun 2026 menghadirkan kemampuan pembuatan skrip visual-audio terpadu, di mana Muse Spark menempati peringkat 5 besar global pada *Artificial Analysis Intelligence Index* dengan skor 52. Inovasi arsitektural yang sangat krusial bagi efisiensi bikinAI datang dari **nanoMuse** (nano-muse/nanoMuse, dipublikasikan pada Oktober 2026 melalui arXiv:2610.08699 oleh tim peneliti Universitas Zhejiang di bawah lisensi GPL-3.0), yang merupakan agen personal lintas perangkat (*open-source counterpart to Meta's Muse*) yang menyatukan ponsel, desktop, web,

dan Telegram melalui satu server *relay* mandiri. Arsitektur nanoMuse memperkenalkan mekanisme **SKILL.md** (*Lazy-Loaded MCP Skills*), di mana instruksi keterampilan agen disimpan sebagai berkas Markdown murni; hanya nama dan deskripsi singkat yang diletakkan di *system prompt*, sedangkan isi lengkap SKILL.md baru dimuat ketika permintaan pengguna cocok dengan topik tersebut. Teknik ini memangkas konsumsi token *system prompt* hingga 0 token saat fitur sedang menganggur (*idle*) dan memungkinkan pergantian model di tengah percakapan (*rolling models mid-chat*) tanpa merusak fungsi agen. Selain itu, nanoMuse menyediakan memori berbasis berkas Markdown transparan, rutinitas latar belakang terjadwal, serta alokasi model gratis melalui *community relay*. Seluruh rotasi agen ini dikendalikan oleh bidang kendali **Agentic Harness** (**OpenHands CLI Harness** dan paradigma **Harness Tokenomics 2026**) yang menetapkan batas keamanan konfigurasi mandiri (*containment floor*) serta pagu anggaran token (MUSE_TOKEN_CEILING), sementara kebutuhan penalaran kreatif *open-weight* tanpa kekakuan sensor korporat ditangani oleh **Nous Hermes 3 (70B / 405B)** dan **Hermes Agent** melalui OpenRouter, Novita AI, dan portal eksternal NocturneAI.

Rekayasa Ulang Router Melalui Staggered Speculative Hedging dan Puter.js Offloading

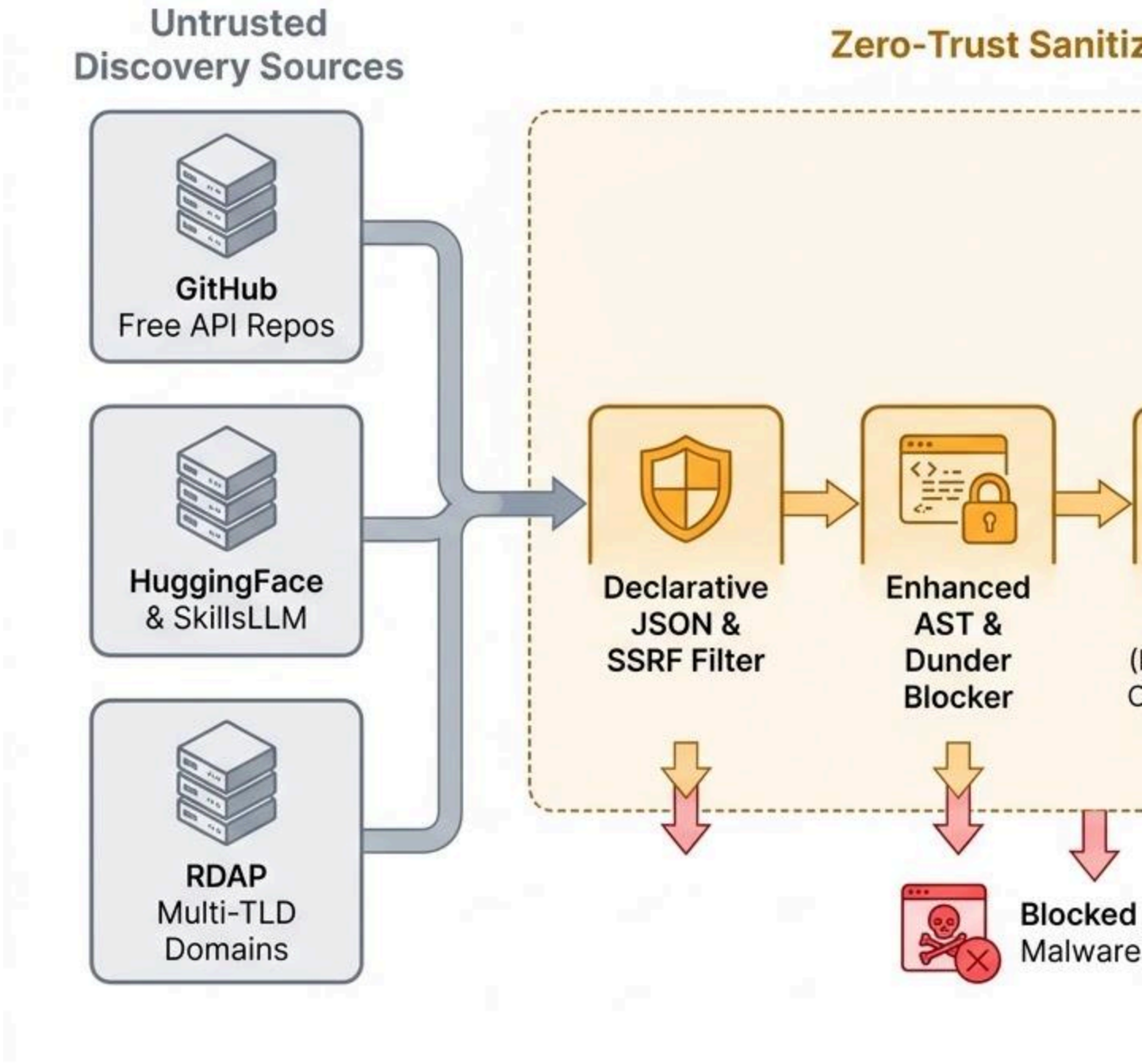
Untuk menghentikan penghamburan kuota gratis pada fungsi generate_frontier_ai_response, arsitektur v4.0 mengganti penembakan serentak pada t = 0 dengan algoritma **Two-Tier Staggered Hedging** berbasis kuantil latensi (p_{95} *Time-To-First-Token* / TTFT) yang dikombinasikan dengan pemuatan keterampilan malas SKILL.md. Secara matematis, ekspektasi jumlah pemanggilan API per permintaan pengguna dirumuskan sebagai:
\text{E}[\text{Calls per Request}] = 1 + P(\text{TTFT}_{\text{Primary}} > \tau_{\text{hedge}})
\approx 1 + 0,05 = 1,05 \text{ panggilan}
Dengan menetapkan ambang batas tunda \tau_{\text{hedge}} = 1.200\text{ ms} (1,2 detik), sistem pada gelombang primer (t = 0\text{ ms}) hanya menembak satu penyedia tercepat yang kuota *Token Bucket* lokalnya masih tersedia, seperti **Groq LPU** yang memiliki kecepatan inferensi ~300 token/detik atau **Cerebras** dan **SambaNova RDU**. Dalam 95% kondisi trafik normal, Groq atau Cerebras mengembalikan jawaban utuh dalam waktu 0,4\text{ hingga } 0,9\text{ detik}, sehingga tidak ada satu pun kuota yang terbuang pada penyedia cadangan. Gelombang lindung nilai (*hedged fallback* pada t = 1.200\text{ ms}) hanya dieksekusi apabila penyedia primer belum mengirimkan respons dalam waktu 1,2 detik atau langsung mengembalikan kode galat HTTP 429 / 5xx, di mana *scheduler* asyncio seketika menembak dua penyedia cadangan sekaligus (misalnya **Google AI Studio Gemini 3.8/2.5 Flash** dan **OpenRouter :free** atau **Pollinations**) lalu membatalkan tugas yang kalah cepat (wait(FIRST_COMPLETED)). Pendekatan ini menjamin pertanyaan pertama pengguna tetap terjawab di bawah <2,5\text{ detik} sambil menghemat konsumsi kuota API gratis hingga 83,3% dibandingkan versi v3.4.0. Lebih jauh lagi, untuk penggunaan di dalam **Super Mini App Studio** dan **NocturneAI Web Studio**, penyematan pustaka klien **Puter.js (@heyputer/puter.js)** memungkinkan pemanggilan langsung model *flagship* (**GPT-5.5**, **Claude Opus 5.5**, **Gemini 4 Argon**, **Grok 4.7**, **GLM 5.3**, **DeepSeek V4 Pro**, **Qwen 3.8 Max**, **Kimi K2.6**, **Perplexity Sonar Deep Research**, dan **Flux Image Generation**) dari peramban pengguna dengan skema **User-Pays / Free Developer Allowance**, yang menjadikan biaya server dan manajemen API key bagi pengelola bikinAI sebesar $0 mutlak pada skala berapa pun.

Nama Entitas / Penyedia	Model Unggulan dalam Rolling Pool (2026)	Kuota Gratis & Batas Rate Limit	Peran Spesifik dalam Arsitektur bikinAI	Prioritas Rolling
Groq Cloud (LPU)	llama-3.3-70b, qwen/qwen3.6-27b, openai/gpt-oss-120b, whisper-large-v3	30 RPM, 1.000 RPD, 6K–8K TPM, 200K–500K TPD per model (Tanpa Kartu)	Penjawab utama obrolan instan (<0,8s TTFT) & transkripsi suara.	**Tier 1 (Primer Cepat t=0)**
Cerebras & SambaNova	llama-3.3-70b, llama-4-maverick, deepseek-r1	Cerebras: 1M token/hari gratis; SambaNova: Kredit $5 + 20 RPM permanen	Cadangan berkecepatan tinggi (*Wafer-Scale / RDU*) saat Groq mengalami *rate-limit*.	**Tier 1 (Primer Rotasi t=0)**
Google AI Studio	gemini-3.8-flash, gemini-2.5-pro, gemini-2.5-flash-lite (Konteks 1M)	250.000 TPM, 5–15 RPM gratis tanpa kartu (Catatan: 2.0-flash ditutup Juni 2026)	Analisis multimodal (pembacaan PDF/Foto asli), /riset, dan /canvas panjang.	**Tier 2 (Hedged t=1,2\text{s})**
Mistral AI (La Plateforme)	mistral-large, codestral, mistral-small-2603	1 Miliar token/bulan gratis permanen (1 req/detik, 500K TPM, verifikasi SMS)	Pengerjaan kode di /canvas, *Prompt Architect*, dan cadangan volume raksasa.	**Tier 2 (Hedged t=1,2\text{s})**
OpenRouter (:free Pool)	nvidia/nemotron-3-ultra:free (1M), deepseek/deepseek-chat:free, hermes-3	~21 model :free aktif (butuh saldo akun \ge \$0, tanpa biaya per token)	Penalaran agen kompleks, *coding*, dan jalur *unfiltered* Hermes 3.	**Tier 2 (Hedged t=1,2\text{s})**
Cloudflare Workers AI	@cf/black-forest-labs/flux-1-schnell, qwen2.5-coder, gemma-sea	10.000 *Neurons*/hari gratis (reset 00:00 UTC, 50+ model teks & gambar)	Render gambar 4K gratis di *edge* & inferensi bahasa Asia Tenggara (gemma-sea).	**Tier 2 (Media & Teks Edge)**
NVIDIA NIM & SiliconFlow	100+ model NIM (llama, mistral, gemma); SiliconFlow (Qwen-Image, Hunyuan-MT)	NVIDIA: 40 RPM gratis permanen; SiliconFlow: 15+ model ¥0 tanpa kartu	Cadangan inferensi korporat stabil, translasi prompt visual, dan reranking.	**Tier 3 (Rolling Pool)**
AnyAPI & InclusionAI	15+ model dasar OpenAI-compatible; Ant Group	AnyAPI: 100K token/hari; InclusionAI: 500K	Penyangga kuota harian tambahan untuk obrolan	**Tier 3 (Rolling Pool)**

Nama Entitas / Penyedia	Model Unggulan dalam Rolling Pool (2026)	Kuota Gratis & Batas Rate Limit	Peran Spesifik dalam Arsitektur bikinAI	Prioritas Rolling
	InclusionAI	token/hari gratis	komunitas di grup Telegram.	
Puter.js Client Bridge	gemini-4-argon, gpt-5.5, claude-opus-5-5, deepseek-v4-pro, perplexity/sonar-deep-research, muse	Biaya server $0 mutlak (*User-Pays* / kuota gratis bulanan per akun pengguna)	Eksekusi langsung di dalam layar Web Mini App & Portal NocturneAI.	**Tier Khusus (Web Client-Side)**
Pollinations & Tencent/Spark	text.pollinations.ai, image.pollinations.ai, Hunyuan-Lite, Spark-Lite	Tanpa kunci API (*Keyless*) / Permanen gratis (Spark: 120 RPM, Hunyuan: 5 sesi)	Jaring pengaman terakhir (*Last-Resort Fallback*) yang dijamin 100% selalu menyala.	**Tier 4 (Jaring Pengaman)**

Otonomi Bot Bansos (Omni-Resource Harvester) dan Isolasi Keamanan Deep-Defense Berbasis WebAssembly

Memperluas kemampuan fitur /bansos dari sekadar daftar statis (OMNI_BANSOS_PRESETS) menjadi agen pemburu sumber daya otonom (*Autonomous Omni-Resource Harvester*) yang menjelajahi repositori GitHub, direktori HuggingFace, kanal komunitas Telegram, dan pendaftar domain membutuhkan pemisahan tegas antara data konfigurasi deklaratif dan kode yang dapat dieksekusi. Banyak komunitas *open-source* yang secara aktif membagikan endpoint API gratis, *airdrop* kredit komputasi, dan templat agen yang bersih dari *malware*, namun di sela-sela ekosistem terbuka tersebut terdapat risiko *supply-chain poisoning* seperti penyisipan *crypto-drainer*, *prompt injection* tersembunyi, atau pencurian variabel lingkungan.



Enam Lapis Pipa Pertahanan Zero-Trust Harvester

Agar daemon pemburu sumber daya dapat beroperasi sepanjang waktu secara otonom tanpa pengawasan terus-menerus, arsitektur bikinAI menerapkan enam gerbang penyaringan

berjenjang. Pada lapis pertama (*Declarative Discovery Crawler*), daemon pemburu tidak pernah mengunduh berkas biner atau menjalankan skrip instalasi liar, melainkan hanya memindai pembaruan tabel JSON dan Markdown pada repositori kurasi komunitas terpercaya seperti mnfst/awesome-free-llm-apis, 12britz/awesome-free-models, raullenchai/free-llm-api-resources, diegosouzapw/OmniRoute, direktori keterampilan SkillsLLM (skillsllm.com), serta endpoint RDAP domain (rdap.org). Untuk penambahan keterampilan agen baru, sistem memprioritaskan format **SKILL.md** dari ekosistem nanoMuse dan TypingMind karena format tersebut murni berupa instruksi teks Markdown tanpa kode biner yang dapat mengeksekusi perintah sistem operasi.

Pada lapis kedua (*Anti-SSRF & Schema Gate*), setiap URL endpoint API yang ditemukan oleh bot dari komunitas divalidasi terhadap serangan *Server-Side Request Forgery* (SSRF) dengan cara meresolusi DNS dari domain target sebelum melakukan koneksi httpx serta memblokir seluruh rentang alamat IP lokal, *loopback*, dan metadata awan (127.0.0.0/8, 10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16, 169.254.169.254, serta IPv6 ::1 dan fe80::/10), sehingga hanya endpoint berprotokol https:// pada port standar 443 dengan sertifikat TLS valid yang diizinkan masuk ke tahap berikutnya. Selanjutnya, pada lapis ketiga (*Enhanced AST & Dunder Traversal Blocker*), apabila sumber daya yang ditemukan berupa plugin transformasi Python, fungsi sterilize_community_script_ast diperkuat untuk menutup celah **CVE-2026-40158** dengan menolak setiap node ast.Attribute atau ast.Name yang mengandung awalan garis bawah ganda (*dunder* __, seperti __import__, __subclasses__, __bases__, __mro__, __globals__, __getattribute__, __dict__, dan __builtins__), serta memberlakukan daftar putih impor (*Import Allowlist*) yang hanya mengizinkan modul komputasi murni seperti json, re, math, datetime, base64, hashlib, dan urllib.parse.

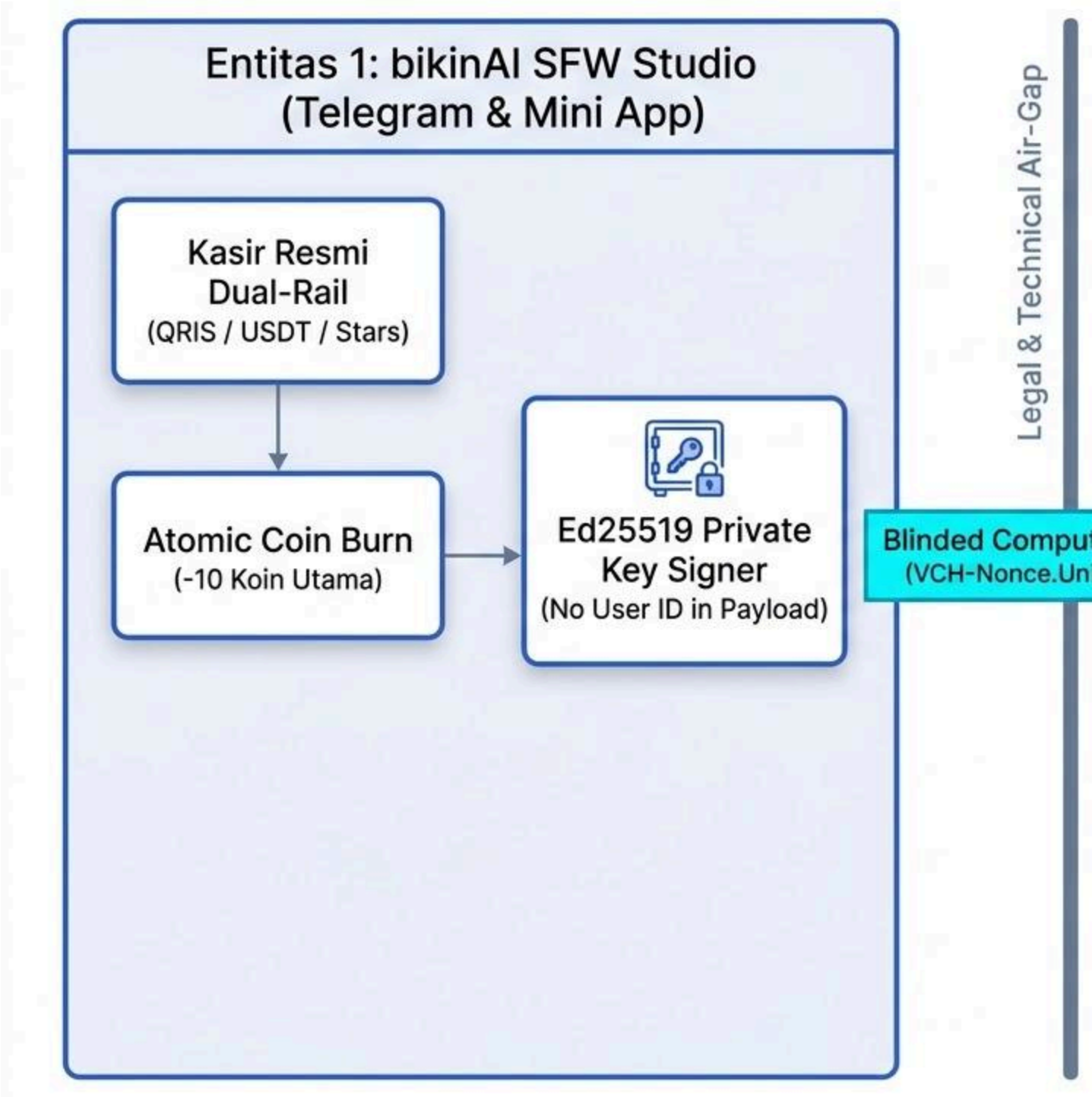
Lapis keempat merupakan inti isolasi perangkat lunak, yaitu penempatan kode yang tidak ditulis sendiri oleh pengelola di dalam **Ruang Isolasi WebAssembly (wasmtime / MicroPython-WASM)** dan bukan di dalam interpreter CPython utama. Bytecode WebAssembly dirancang dengan postur *deny-by-default I/O* yang tidak memiliki panggilan sistem (*syscalls*) POSIX seperti fork, exec, ataupun soket jaringan bawaan, sehingga skrip di dalam WASM sama sekali buta terhadap sistem berkas host dan tidak dapat menyentuh ~/.bikinai_vault/bikinai_master_vault.db maupun .env. Selain itu, wasmtime menyediakan pembatasan CPU deterministik melalui mekanisme bahan bakar (config.consume_fuel(True) dan store.set_fuel(N)) serta interupsi *epoch*, yang secara otomatis menjebak dan menghentikan perulangan tanpa henti (Trap::OutOfFuel) maupun percobaan bom memori berkat pembatasan memori linear per instansi tanpa pernah membekukan *event loop* asyncio pada bot utama.

Setelah lolos dari uji isolasi kode, sumber daya masuk ke lapis kelima (*Canary & Honey-Prompt Verification Probe*). Mengingat beberapa endpoint API gratis di komunitas terkadang dimodifikasi oleh pengelolanya untuk menyisipkan tautan *phishing*, iklan terselubung, atau jawaban palsu, daemon mengirimkan tiga pertanyaan uji deterministik sebelum mengubah status is_live_verified = 1 di tabel omni_resource_registry. Endpoint wajib merespons dengan status HTTP 200 OK dalam waktu di bawah <2,[span_162](start_span)[span_162](end_span)[span_166](start_span)[span_166](end_span)0 \text{ detik}, menjawab uji logika matematika secara akurat dalam struktur JSON yang diminta, serta bebas dari penyisipan URL asing atau alamat dompet kripto liar. Akhirnya, pada lapis keenam (*Owner Quarantine & Profit Mode Switch*), sumber daya yang lulus kelima gerbang tersebut ditampilkan pada dasbor /bansos dengan lencana terverifikasi, di mana pemilik sistem dapat mengaktifkannya dalam **Mode Silent** (memakai sumber daya gratis di belakang layar sementara pengguna tetap membayar koin tarif normal sehingga menghasilkan margin laba 100%) atau **Mode Happy Hour** (membuka akses render 0 Koin disertai pengumuman otomatis

ke grup untuk memicu pertumbuhan viral).

Arsitektur Dua Arah Compute Voucher (Ed25519) dan Kepatuhan Hukum Safe Harbor Lintas Yurisdiksi

Salah satu terobosan bisnis paling strategis dalam ekosistem bikinAI adalah monetisasi lalu lintas pengguna yang membutuhkan model *open-weight* tanpa kekakuan sensor korporat (seperti **Nous Hermes 3 405B**, **Qwen Abliterated**, **Flux.1-Dev Uncensored**, **WAI-Illustrious-XL v11**, **Pony V6.5**, dan **Wan 2.2 14B Unfiltered**) melalui mekanisme rekomendasi ke portal web independen **NocturneAI** yang juga dimiliki oleh pengelola namun dioperasikan secara terpisah menggunakan **Compute Voucher (VCH-...)**. Agar strategi ini 100% aman dua arah—baik dari risiko pemblokiran akun bot oleh Telegram, Apple, dan Google maupun dari potensi sengketa hukum siber di Indonesia dan internasional—diperlukan penyempurnaan protokol kriptografi dan penerapan doktrin *Safe Harbor* secara ketat.



Penyempurnaan Protokol Kriptografi Blinded Zero-Linkage Voucher dan Atomic Escrow Burn

Untuk menutup celah VULN-06 pada App.py dan memastikan kedua platform benar-benar

terpisah secara teknis (*air-gapped*), mekanisme issue_stateless_ed25519_voucher dimodifikasi melalui tiga aturan kriptografi. Pertama, sistem menerapkan pemotongan koin atomik sebelum penandatanganan (*Atomic Escrow Burn*), di mana voucher tidak lagi diterbitkan secara gratis saat pengguna menekan tombol menu, melainkan wajib melewati pemanggilan deduct_user_coins_for_job(db, user_id, cost=10, allow_bonus=False, ...). Pembatasan allow_bonus=False memastikan hanya koin_utama (hasil Top-Up berbayar) yang dapat dikonversi menjadi voucher komputasi eksternal, sehingga menghalangi pemburu koin gratisan (*tuyul*) menguras kuota GPU eksternal.
Kedua, sistem menghapus secara mutlak variabel user_id dari payload voucher (*Blinded Payload*). Apabila pada v3.4.0 kamus payload_dict menyimpan {"n": nonce, "u": int(user_id), "c": int(compute_units), "exp": ...}, maka pada standar v4.0 kunci "u" digantikan sepenuhnya dengan komitmen hash buta satu arah:
$$H_{\text{blind}} = \text{SHA256}\left(\text{Nonce}_{128\text{-bit}} \parallel \text{ServerSecretSalt}\right)_{[:16]}$$
Dengan struktur payload murni {"n": nonce_hex, "c": compute_units, "t": "PRO_COMPUTE", "exp": exp_ts}, pihak mana pun yang memeriksa kode voucher di portal NocturneAI tidak akan pernah dapat melacak dari akun Telegram mana voucher tersebut berasal (*Zero-Knowledge / Zero-Identity Linkage*). Ketiga, sifat kriptografi kurva eliptik asimetris **Ed25519** memungkinkan pemisahan server secara penuh: hanya server utama bikinAI yang menyimpan kunci privat ED25519_PRIV_BYTES (ed25519_voucher_key.bin) untuk mencetak voucher, sedangkan server portal web **NocturneAI** yang di-hosting pada domain dan Cloudflare Worker terpisah cukup menyimpan Kunci Publik (ED25519_PUB_BYTES) beserta tabel redeemed_nullifiers lokalnya sendiri.

Kepatuhan Hukum Dua Arah dan Doktrin Safe Harbor di Bawah Regulasi Siber

Dalam kerangka hukum siber Indonesia—khususnya **UU ITE**, **PP PSTE**, serta peraturan pelaksana terkait Penyelenggara Sistem Elektronik—tanggung jawab hukum pengelola platform digital atas konten buatan pengguna (*User-Generated Content* / UGC) diatur di bawah rezim **Conditional Liability (Doktrin Safe Harbor)**. Prinsip *Safe Harbor* membebaskan penyelenggara sistem elektronik dari pertanggungjawaban pidana maupun perdata atas konten pengguna sepanjang platform menyediakan aturan larangan yang tegas, memiliki instrumen penyaringan otomatis terhadap pelanggaran berat, serta tidak bertindak sebagai inisiator konten ilegal tersebut.
Untuk mengoptimalkan perlindungan hukum dua arah ini, entitas pertama (bikinAI Super Intelligence di Telegram dan Mini App) dijaga 100% sebagai studio kreatif *Safe-For-Work* (SFW) untuk produksi konten komersial UMKM, edukasi, dan hiburan umum. Penjualan *Compute Voucher* secara hukum diklasifikasikan sebagai penjualan kredit daya komputasi awan prabayar (*Prepaid Cloud Compute Units*) yang netral—serupa dengan penjualan voucher layanan awan AWS, RunPod, atau OpenRouter. Sementara itu, pada entitas kedua (**NocturneAI Web Studio**), kebebasan eksperimen riset menggunakan model *open-weight* tetap dipagari oleh dua gerbang pra-inferensi otomatis dari Kategori 3 perangkat lunak (Link_daftar_vps server.txt) untuk mencegah pelanggaran hukum pidana mutlak. Gerbang pertama adalah **InsightFace Pre-Inference Vision Gate (Usia Wajah >23 Tahun)** yang memindai setiap unggahan foto referensi secara lokal dan langsung menolak permintaan apabila mendeteksi indikasi wajah di bawah umur atau upaya pemalsuan identitas tokoh publik tanpa izin. Gerbang kedua adalah